Control de Turnos por Token

Introducción

Tras detectar en la fase anterior que cualquier usuario podía mover piezas ajenas, el objetivo de esta issue ha sido blindar la lógica del juego. He modificado el núcleo de la aplicación (`api.php`, `DB.php` e `index.html`) para implementar un sistema de tokens SHA-256 que identifica a cada jugador de forma única y privada.

Este cambio asegura que, aunque el juego esté expuesto a internet, sea imposible interferir en partidas de terceros sin poseer la clave secreta de la sesión.

Funcionamiento del Sistema de Tokens

El nuevo flujo de seguridad se basa en la generación de secretos únicos en el momento de creación de la partida:

1. **Generación Atómica:** Al crear una partida, el servidor genera dos tokens distintos (uno para el color Rojo y otro para el Negro). Estos tokens se devuelven al cliente solo una vez y nunca vuelven a viajar por la red a menos que sea en una petición de movimiento.
2. **Enlaces Personalizados:** Cada jugador recibe una URL única que lleva su token incrustado. Este token actúa como su "firma" digital para esa partida.
3. **Validación Robusta:** Cuando se intenta realizar un movimiento, la API extrae el token de la petición y lo compara con el almacenado en la base de datos usando la función `hash_equals()`. Esta función es vital ya que protege el sistema contra **ataques de timing**, evitando que un atacante adivine el token midiendo el tiempo de respuesta del servidor.

Implementación en los Componentes

Backend: API y Base de Datos

He actualizado la lógica para que el servidor sea "consciente" de quién está enviando los datos:

- **Endpoint `identificar`:** Añadí una función en la API que el frontend consulta al cargar la página. El servidor responde qué color le corresponde a ese token (`R` o `N`).
- **Validación de Turno:** Antes de aplicar cualquier cambio en el tablero, la API verifica si el token enviado corresponde al turno activo. Si no coinciden, el servidor corta la petición con un error HTTP 403.

- **Registro de Movimientos:** Cada jugada válida se registra ahora en la tabla `movimientos`, vinculando el ID de la partida con el jugador que realizó la acción para tener trazabilidad total.

Frontend: Bloqueo Visual

En el archivo `index.html`, he programado un filtro para que el tablero se adapte a la identidad del jugador:

- Si eres el jugador Negro, el sistema bloquea automáticamente cualquier interacción con las piezas rojas.
- Se ha añadido un panel visual que indica claramente si es tu turno o si debes esperar al rival.

Verificación y Despliegue

Para confirmar que los cambios no introdujeron errores en el servidor, realicé una verificación de sintaxis de todos los ficheros modificados dentro del contenedor Docker.

```
Last login: Wed Apr 29 02:26:15 2026 from 188.26.195.48
ubuntu@ip-10-1-0-85:~$ sudo docker exec mi_proyecto_web_web_1 php -l /var/www/html/api.php
No syntax errors detected in /var/www/html/api.php
ubuntu@ip-10-1-0-85:~$ sudo docker exec mi_proyecto_web_web_1 php -l /var/www/html/index.html
No syntax errors detected in /var/www/html/index.html
ubuntu@ip-10-1-0-85:~$ nano /home/ubuntu/mi_proyecto_web/html/index.html
ubuntu@ip-10-1-0-85:~$ sudo docker exec mi_proyecto_web_web_1 php -l /var/www/html/index.html
No syntax errors detected in /var/www/html/index.html
```

(Evidencia de `php -l` confirmando que api.php, DB.php y GameLogic.php están libres de errores tras la implementación de los tokens).

Además, comprobé que el servidor web sirve la nueva versión del juego con los 4 ficheros actualizados en su volumen correspondiente.

```
ubuntu@ip-10-1-0-85:~$ sudo docker exec mi_proyecto_web_web_1 ls -lh /var/www/html/
total 56K
-rw-rw-r-- 1 1000 1000 5.0K Apr 29 02:41 DB.php
-rw-rw-r-- 1 1000 1000 8.8K Apr 29 02:39 GameLogic.php
-rw-rw-r-- 1 1000 1000 7.8K Apr 29 02:41 api.php
-rw-rw-r-- 1 1000 1000  25K Apr 29 02:45 index.html
```

(Listado de archivos en /var/www/html/ tras el despliegue del sistema de seguridad).

Conclusiones

Con la Issue cerrada, hemos resuelto la mayor vulnerabilidad lógica del proyecto. Ahora, conocer el código de una partida no es suficiente para manipularla; se requiere el token secreto generado por el sistema.

Este diseño no solo hace el juego ciberseguro para su uso en internet, sino que demuestra una arquitectura profesional de gestión de sesiones sin estado, donde cada movimiento queda auditado en la base de datos con nombre y apellido.